A3-PS011-TC025

Authorized Attack-Surface Inventory & Change Monitor

Sidharth P S
sidharth.ps@btech.christuniversity.in
Tarun M
Tarun.m@btech.christuniversity.in
Dr. Jyothi Mandala
jyothi.mandala@christuniversity.in

AIORI Hackathon
3 October 12, 2026

The problem: assets change faster than inventories

WHAT ORGANIZATIONS MISS

- Forgotten test subdomains and retired hosts
- Expired or mismatched TLS certificates
- Unexpectedly exposed network services
- DNS records that may point to decommissioned resources
- Changes that go unnoticed between manual checks

OUR GOAL

Discover → Compare → Verify → Prioritize → Alert

Monitor up to 20 approved lab domains and 10 hosts. Detect seeded issues, preserve evidence, and report false positives.

Why an attack-surface baseline matters

ASSET INVENTORY	CHANGE DETECTION	ACTIONABLE RESPONSE
What domains, DNS records, certificates and services are currently observed?	What is new, missing, expired, altered or no longer resolving?	What evidence supports the finding, how confident are we, and what should be checked next?

Design principle: preserve observations and uncertainty—never treat a failed scan as proof that an asset disappeared.

Standards-informed, scope-controlled design

Use established security guidelines to guide asset discovery, configuration checks and evidence-based reporting.

STANDARDS:

OWASP WSTG: Reference for systematic security testing methodology.
NIST SP 800-115: Technical guidance for security testing and assessment.
RFC 1034 / RFC 1035: DNS concepts, records and name resolution.
RFC 8446: TLS 1.3 protocol and secure connection standards.
RFC 5280: X.509 certificate validation and certificate validity information.

RESEARCH:

Written authorization: Scan only organizer-approved domains and hosts.
Restricted scope: Enforce target allowlists and documented port checks.
Safe discovery: No exploitation or unrestricted scanning.
Verified findings: Repeat checks and distinguish DNS failures from potential dangling records.

Proposed Solution: Attack Surface Sentinel

1. REGISTER

•Add approved domains and hosts.

•Define the authorized port allowlist.

2. COLLECT

•Collect DNS records.

•Retrieve TLS certificate metadata.

•Check TCP port states.

3. STORE

•Store timestamped observations.

•Maintain baseline snapshots for comparison.

4. COMPARE

•Detect newly discovered or removed assets.

•Identify configuration changes.

5. VERIFY

•Recheck ambiguous findings.

•Calculate confidence in detected changes.

6. ALERT

•Prioritize findings based on risk.

•Present supporting evidence.

•Provide remediation recommendations

What improves over a basic scanner?

The value is the quality of decisions, not the number of ports scanned.

BEFORE	PROPOSED IMPROVEMENT	BENEFIT
Basic scan output	Timestamped asset inventory	Traceable history
One-off findings	Baseline vs. current comparison	Explain exactly what changed
Any DNS failure = alert	Repeated checks + result classification	Fewer unsupported alerts
Unranked issue list	Risk + confidence + evidence	Review highest-priority findings first
Manual screenshots	Exportable report + audit history	Repeatable evaluation

Solution Architecture & Design

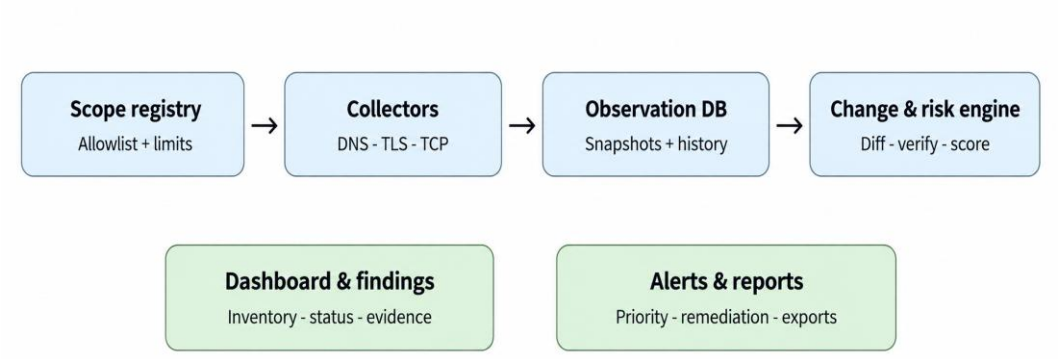
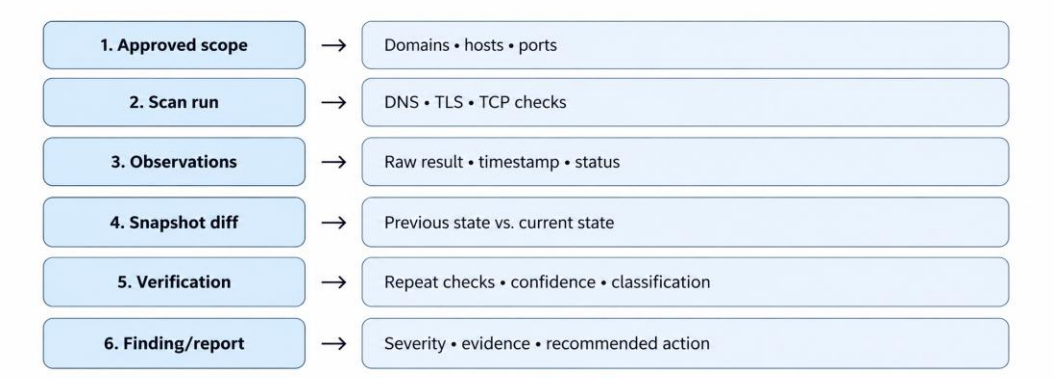


Figure: System Architecture UML Diagram

From scan to defensible finding



Data Flow Diagram (DFD)

Deployment Timeline

Phase	Work	Exit check
1 · Days 1–3	**Core setup:** Project structure, database, authorized-scope registry, DNS collector and initial asset inventory.	Approved targets are enforced; DNS observations are recorded with timestamps.
2 · Days 4–7	**Core checks & baseline:** TLS certificate checks, TCP port checks, snapshot storage, comparison rules and finding classification.	Expired TLS, unexpected services and asset changes are detected in controlled tests.
3 · Days 8–11	**Change engine & dashboard:** Repeat verification, risk and confidence scoring, evidence-based alerts, dashboard and report exports.	Findings show supporting evidence, priority and recommended remediation.
4 · Days 12–14	**Integration & validation:** End-to-end testing, seeded issue scenarios, false-positive checks, scope enforcement, documentation and final demo.	Demo runs successfully; detection results, false positives and evidence completeness are documented.

Method: Use an authorized lab, fixed test cases and repeatable checks. Preserve timestamps and baseline history; distinguish DNS timeouts and server failures from potential dangling records. If a check fails, do not automatically treat the asset as removed.

Bibliography I

[1] IETF. “Domain Names — Concepts and Facilities.” In: *RFC 1034* (Nov. 1987).
[2] IETF. “Domain Names — Implementation and Specification.” In: *RFC 1035* (Nov. 1987).
[3] IETF. “The Transport Layer Security (TLS) Protocol Version 1.3.” In: *RFC 8446* (Aug. 2018).
[4] IETF. “Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile.” In: *RFC 5280* (May 2008).
[5] NIST. “Technical Guide to Information Security Testing and Assessment.” In: *NIST SP 800-115* (Sept. 2008).
[6] OWASP Foundation. “Web Security Testing Guide (WSTG).” [7] IETF. “HTTP Semantics.” In: *RFC 9110* (June 2022).

Thank You for Your Attention!